ZippelLabs

helping secure the world's biggest privacy and scaling protocols

What don't we know?

AI, ZK Auditing and zkVM

Zero-knowledge proofs security

Vishal Singh

“If crypto all goes at zero

at least it gave us

Zero Knowledge proofs”

Current state of zk applications?

$28-30b

- zkVMs: > $5b
- zk-rollups: > $5b
- zkEVM: > $2b
- Zcash
- Private L1/L2s
- zk apps:
  - zkPassport, etc

thisvishalsingh | ZippelLabs @thisvishalsingh · Mar 10

Huge

AFAIK, @paradigm and @a16zcrypto, lead this seed will bring great momentum to privacy as a first-class citizen.

This is a good signal after strawmap.org L1 roadmap.

Zashi → Zodl @zodl_app · Mar 9

Zcash Open Development Lab Raises $25M+ in Seed Funding

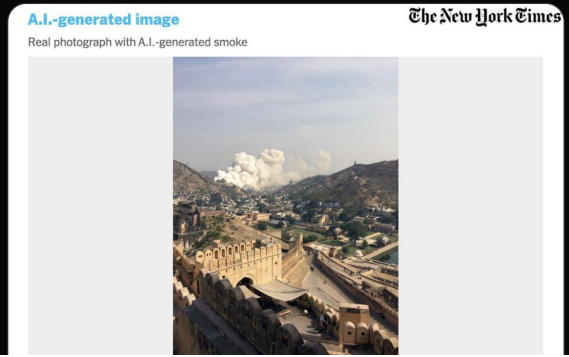
Zcash Open Development Lab (ZODL) has secured over $25 million in funding. This milestone signals strong investor confidence in the growing worldwide adoption of shielded ZEC as digital private money....

Uma Roy @pumatheuma · Feb 27

This week, both Succinct and the @nytimes put AI image detectors to the test. The findings are now making headlines.

Same detectors. Same weaknesses. Same conclusion: AI image detection is an arms race that can't be won.

The only way forward is to Prove What's Real.



Boundless
@boundless_xyz

ZK proof adoption is happening right now, on Boundless.

With ecosystems like @citrea_xyz, @StellarOrg, @Wormhole, @taikoxyz, @megaETH and @Optimism – we are accelerating how crypto teams leverage the ZK stack.

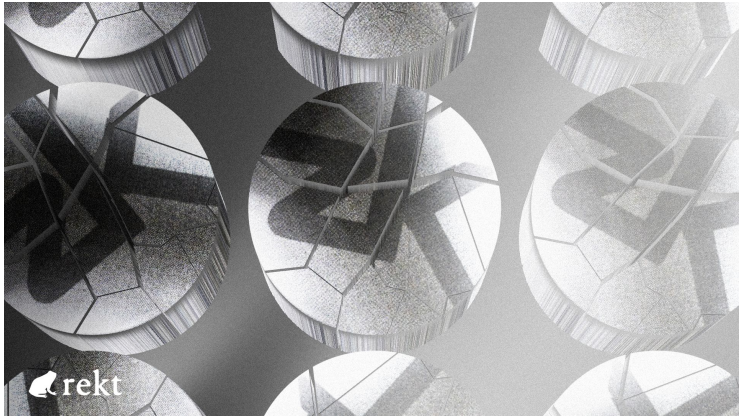
https://l2beat.com/zk-catalog

Current state of zk applications?

zkLend @zkLend · Jun 25, 2025

Dear zkLend Community,

It is with a heavy heart that we announce our decision to wind down zkLend.



Feb-2025: $9.57m due to rounding-down error in withdraw logic

Current state of zk applications?

Vield.Cash - 2.9 ETH, gone in a single transaction.

A few days later, Foom.Cash lost $2.26 million to the identical flaw.

‘The exploit that drains your protocol are simple - it can be as single missing check.’

Last hack wasn't a deep cryptographic flaw or a subtle circuit bug.

It was a deployment mistake - missing one CLI command. And it sat in production with real funds at risk.

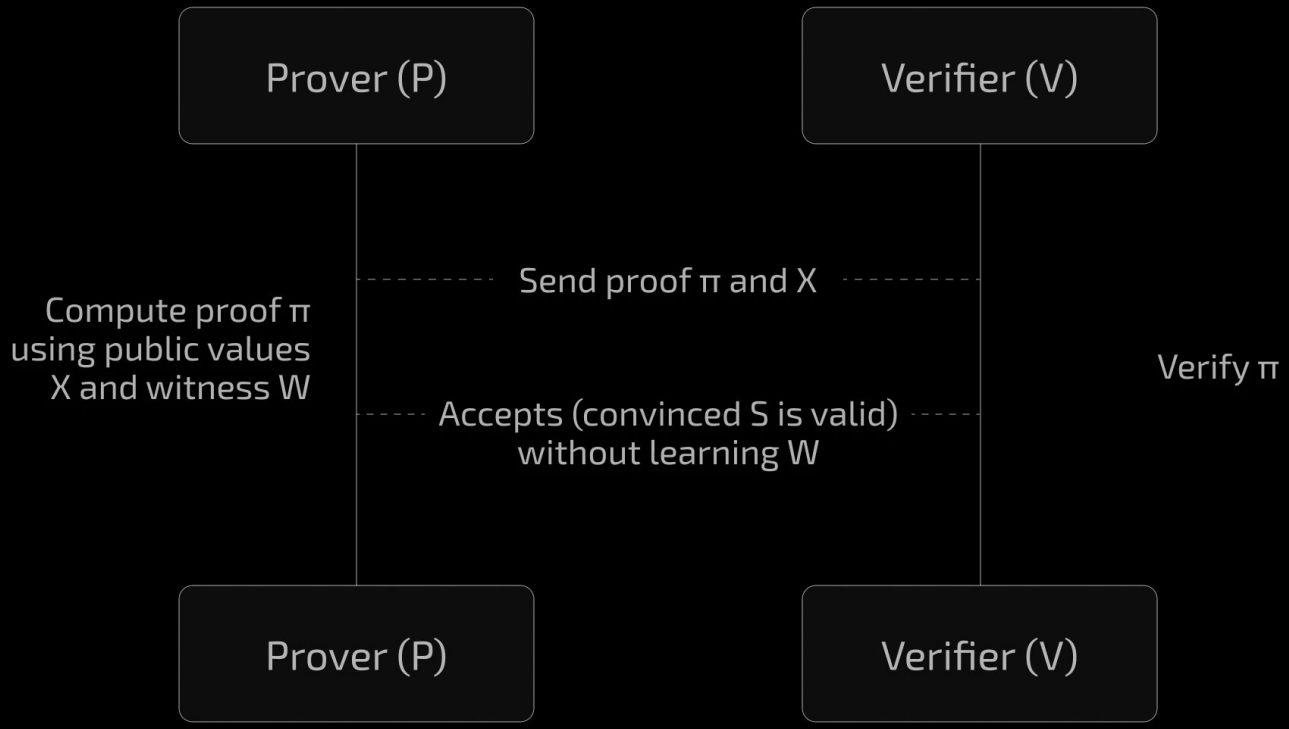
A major risk for Blockchain/zk projects:

- Complexity + Novelty $\Longrightarrow$ Non-trivial bugs.
- A lot at stake: $$$$$$
  - as a bug hunter I like complexity & stake

As a researcher since 2024, the most interesting protocols I've seen

- 'Simple but complex' - non-interactive, but many moving parts
- `Code is LAW`
- `SPECS are LAW`

How Zero-Knowledge Proofs Work



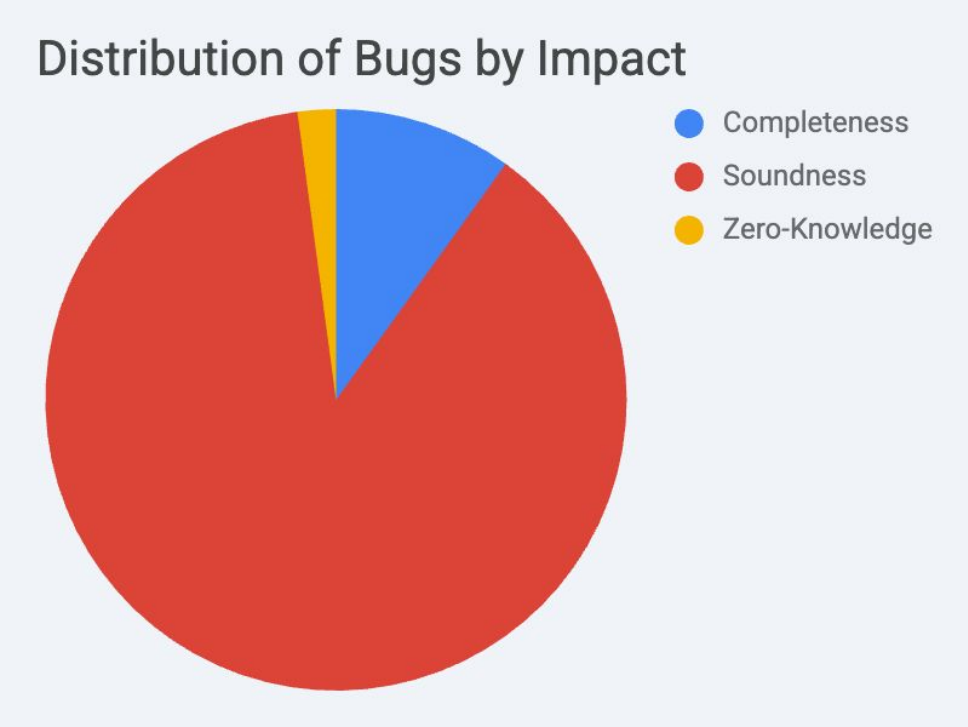
What is zk security? How to break ?

Soundness

Invalid proofs should always be rejected – most obvious attack vector

Forging, altering, replaying valid proofs should be impossible

- Critical-High risk



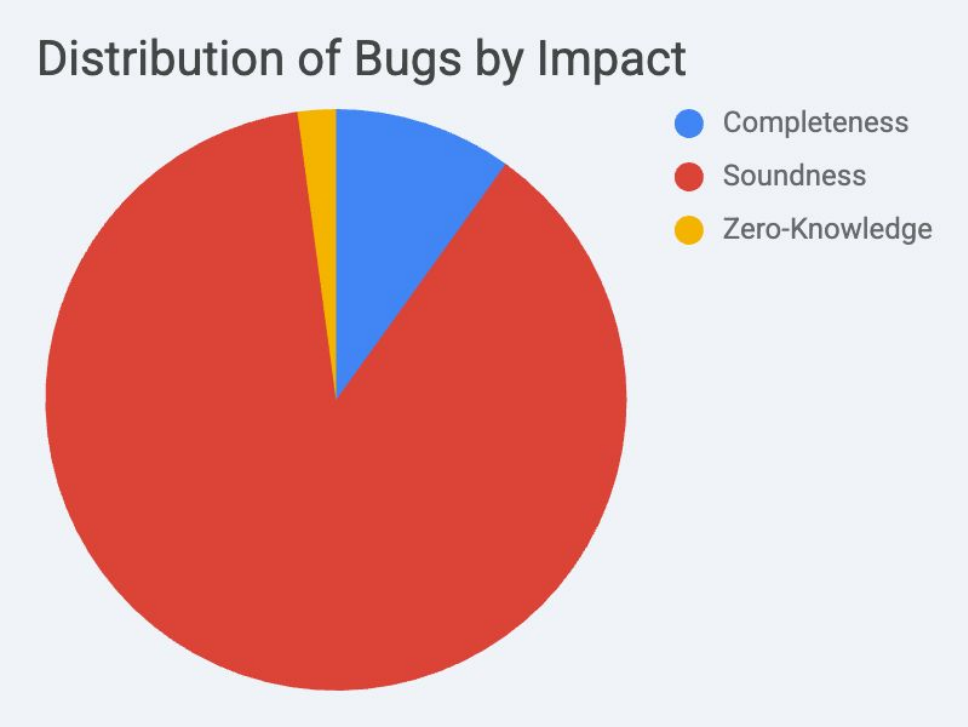
What is zk security? How to break?

Completeness:

Valid proofs should always be accepted

All programs/circuits supported should be correctly processed

- DoS/usability risk

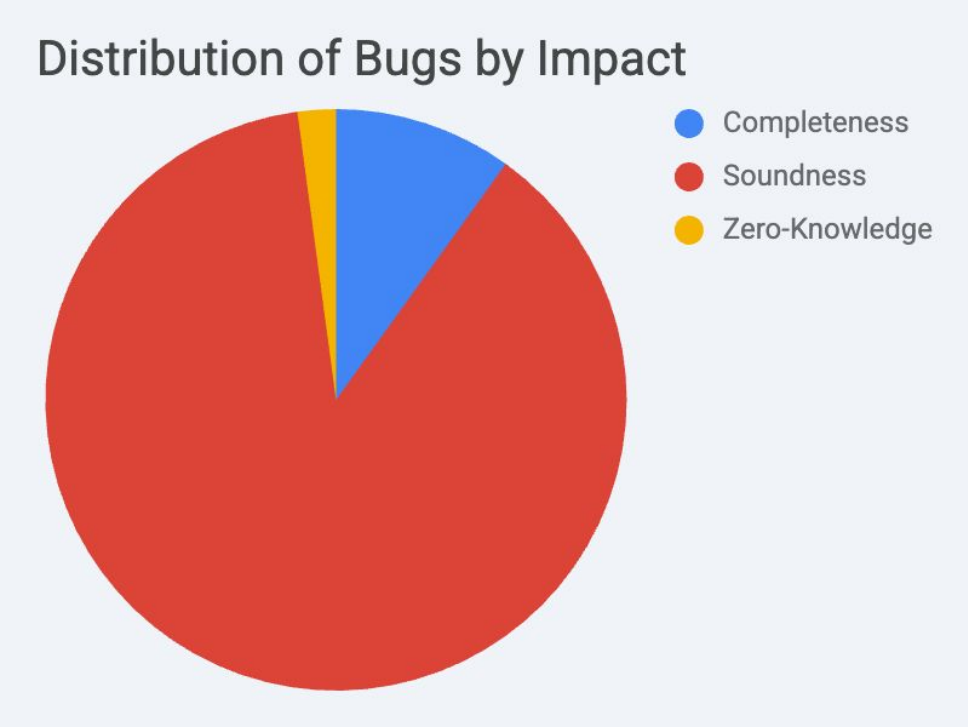


What is zk security? How to break?

Zero-knowledge

Proofs should not leak secret information (witness)

In practice succinct proofs of large programs can leak only little data



‘Should you pay for security audits? ’

Who can find bug? 🐛

A. Developers of the code (manually or via testing)

B. Developers of other projects' code (ex-last plonky3 bug)

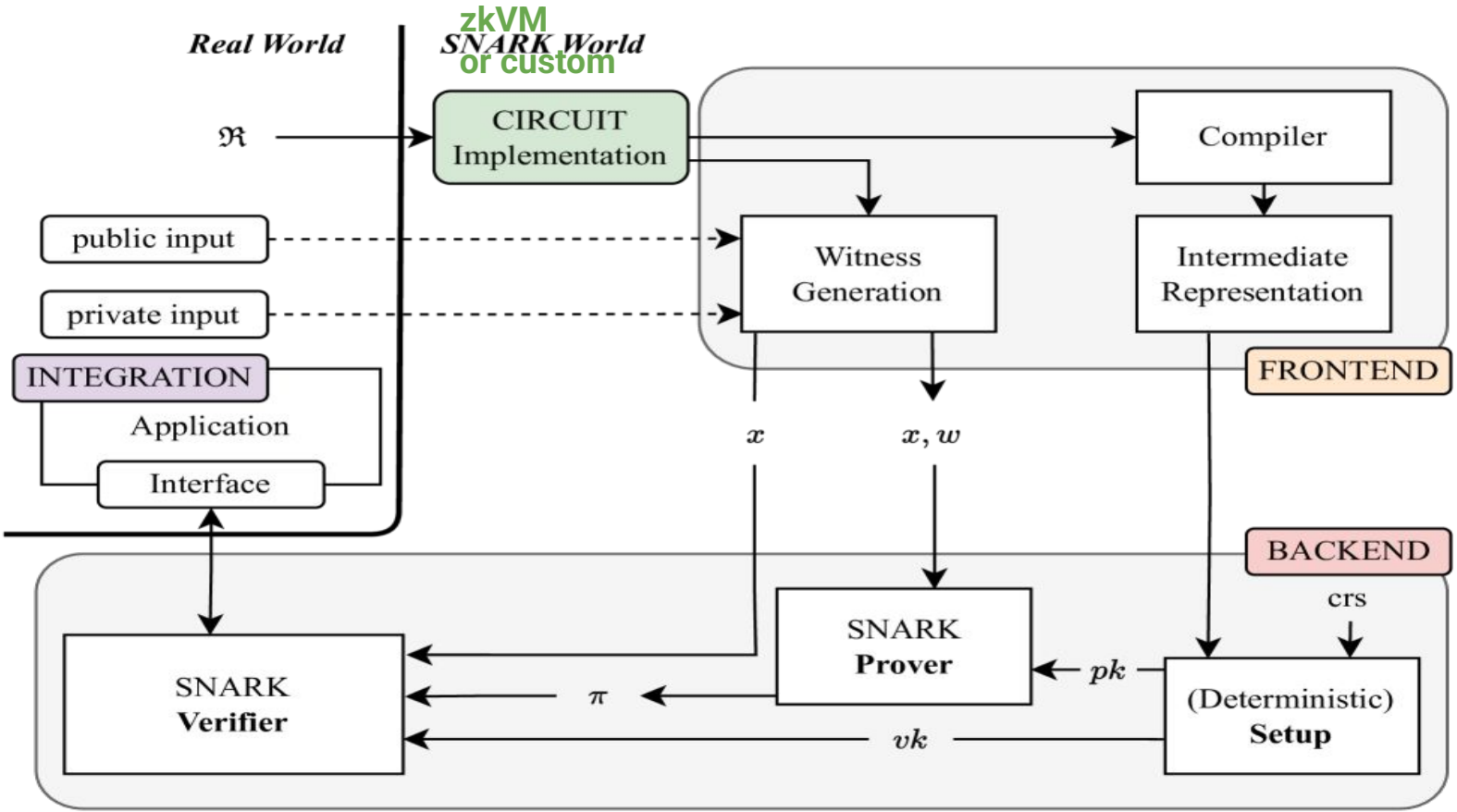
C. External auditors of the code (bb, private audit)

D. Users of the code, accidentally 😇

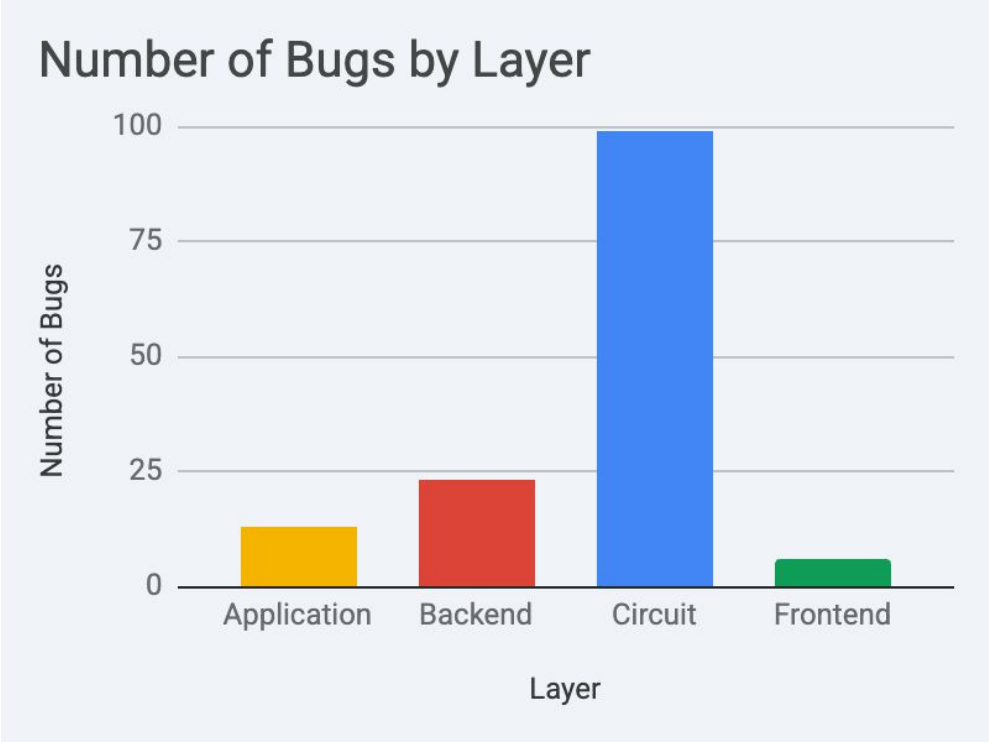
E. And of course...External "attackers" 👹

Security goal: you want A|B|C to find bugs before D|E

Threat model of zkSNARKs?



Where to look in zkSNARKs? 🐛



Where AI helps ?

AI-assisted to AI-augmented & AI-native

- people use AI tools do their jobs faster(chatbots, summarizers)
- Workflows design around AI capabilities(agents in loops, AI-first process)
- The organisation is architect from the ground to up assuming AI as core participant in delivery, and operations

Checklist - as these qns

1. Planning & Design - Which proving system to use? Is the integration with on-chain/off-chain components secure? Are you suing audited libs?
2. Completeness: Are the unit test written to verify the valid witnesses satisfy the circuit?
3. Soundness: Are invalid witnesses fail?(negative test)
4. Is the protocol formally verified?
5. Is the protocol externally audited ? If audited what was scope ? Are all the components of threat model audited externally ?
6. Is the protocol have bug bounty ?
7. Is the protocol re-audited after AI audit and after manual 1st review?

- if any of these are not taken seriously you should scared 😱

Conclusion

Why to be scared?😱

- Few people understand zk proofs, even fewer can find bugs
- Lack of good tooling (wrt testing, fuzzing, verification)
- More ZKPs used => more $$$ at stake => greater RoI for vuln research

Why not to be scared?

- Robust frameworks (due to open-source and use of FV)
- Increase in research and collaborative work from EF, etc
- AI for security is good

Qns?

How to be a zk-auditor/researcher/engineer?

- maths background(algebra-linear/discrete/abstract, number theory)
- proficient in rust(plonky2/3, arkworks, L2s): 30-60 days
- understanding of cryptographic algo used for privacy protocols (Dan Boneh): ~ 60 days
- Deep understanding of VMs: RISC-V & MIPS - 10 days by writing code

Don’t rush think of it as more than 1 year time-horizon

Thank you!

X/tg: @thisvishalsingh

ZippelLabs - zippellabs.github.io/

Slides:

https://github.com/ZippelLabs/publications/tree/main/presentations